

10th International Conference of Information and Communication Technology (ICICT-2020)

Research and application of security baseline in business information system

Yanqing Ding*, Zheng Wu, Zhuantiao Tan, Xin Jiang

China Earthquake Networks Center, Beijing 100045, China

Abstract

Security baseline is an important part of information network security application research. It is a basic requirement for business system security, and is also a prerequisite for conducting security assessments and solving information system security problems. This article studies the basic configuration, state management and security vulnerabilities of the security baseline to design a security baseline research plan. According to the environment configuration and classified protection of the business system, it carding the safety baseline strategy that fits the business system. The security baseline strategy checks the configuration of the business information system, and then performs security hardening on the system, which reducing business system security risks. The research and application of security baselines ensure the normal operation of business systems and reduce the cost of daily system security maintenance.

© 2021 The Authors. Published by Elsevier B.V.

This is an open access article under the CC BY-NC-ND license (<http://creativecommons.org/licenses/by-nc-nd/4.0/>)

Peer-review under responsibility of the scientific committee of the 10th International Conference of Information and Communication Technology.

Keywords: Business information system, security baseline, technical solution, security inspection, security reinforcement ;

1. Introduction

With the development of information construction of business system, the information security risks have become more complex. Building a business system security baseline has become the first step in system security engineering. A large number of safety risks prove that business system security usually needs to balance security costs and security affordability, and the security baseline is the reasonable demarcation point for this balance ^[1]. According to the annual cybersecurity law enforcement inspections and cybersecurity self-inspection work, the security inspection results of some business systems of the enterprise are very dangerous. There are many problems in the security

* Corresponding author. Tel.: 15001256229

E-mail address: geochild@163.com

configuration and basic security protection of the business system, which may affect its normal operation at any time. Therefore, it is necessary to strengthen the research on business system security baselines to improve the security foundation of business systems.

2. Research background

The most important achievement and successful case of the information system security baseline in the world is the FDCC (Federal Desktop Core Configuration) project. FDCC is a desktop system security baseline requirement specification established with the support of the US government, which can be checked through automated tools [2]. In November 2017, the European Network and Information Security Agency released the *IoT Security Baseline Guidelines for Critical Information Infrastructure*, which sets security baselines by analyzing the security requirements, the threat situation and so on, it was proposed practical countermeasures based on security baselines, and makes recommendations on the status of the EU's IoT legislation, standard drafting and policy implementation [3].

The domestic network and information security management work has been paid more and more attention by the state and related units. First of all, at the level of national informatization development strategy, it is proposed in the *National Informatization Development Strategy 2006-2020* to attach great importance to the security of information systems. Secondly, relevant research institutions in China, the telecommunications industry, and the power industry have studied related technologies such as security baseline configuration verification, and released baselines for security configuration of operating systems, databases, switches and other related software and hardware equipment. Domestic information security vendors have also actively conducted research on security baseline configuration and verification technologies, and released some software and products that can perform security configuration baselines. In 2019, China promulgated the *Basic Requirements for the Protection of Network Security Levels (GB/T 22239-2019)*, and proposed a new compliance construction in terms of information security configuration. It also provided a favorable basis for the study of information system security baselines and Protection [4].

3. Security baseline research

3.1. Security baseline

The security baseline is the minimum safety guarantee of the information system, and it is also the most basic safety requirement. The establishment of a business information system security baseline can improve the safety work level of information operation and maintenance personnel and the management efficiency, to ensure that the safe and stable operation of business information systems [5].

3.2. Security baseline composition

The application scope of the security baseline is very broad, which can be subdivided based on the composition of the business information system. According to the basic environment configuration of business information system, such as the operating systems, middlewares, databases and other components, it analyzes system configuration vulnerability, system configuration status, and security vulnerability of each component. Each component of the business system can be described in the following aspects [6]: basic configuration, state management and security vulnerabilities. The specific structure of each part is shown in Fig. 3.1 below:

Basic configuration: Including security configuration of business system accounts, passwords, user rights, security authentication, logs, etc. During these security configuration operations, it is easy to be negligent of human operation. For example, the administrator account, password is too short, or the password is not changed for a long period of time, so that the system is easy to fall into attack. System basic configuration is the most vulnerable part of system security. When designing a business system security baseline solution, basic configuration is a place that needs to be focused on, and it is also the basis for the safe operation of information systems.

State management: Including security configuration of business system ports, traffic, processes, access control policies, etc. The opening of unnecessary ports and processes in the business system is easy to provide a springboard

for attackers, and it also increases the operating load of the business system. The Status management is the most important part in system security, and can ensure the safe and effective operation of information systems.

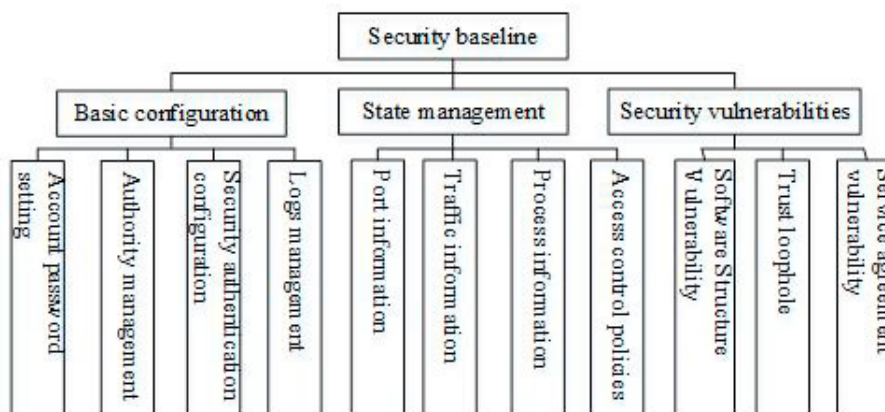


Fig. 3.1. composition of safety baseline

Security vulnerabilities: It refers to defects in the system security policies such as software, trust systems, and protocols. The security flaws in the system can be used by attackers to detect the system without authorization, to achieve the purposes of illegal exploitation and malicious destruction. Management of security vulnerabilities can ensure the continuous and stable operation of business systems well.

4. Technical routes

The configuration of the security baseline has a great correlation with the business system itself. According to the basic composition of the business system and the system network security protection level determine the specific settings of the security baseline. This article mainly studies the business system software components. First, it should be understanding more about the detailed information of the operating systems, databases, middlewares and other software applications of the business system [6]. At the same time, the security protection level of business system needs to be determined. According to the baseline program, it can carry out the corresponding security inspection and technical reinforcement for the business system, and finally output the corresponding technical report.

4.1. System composition type

The business system software part is mainly composed of the operating systems, databases, middlewares, and other software. This is the specific object to be protected in the security work of the business system. The category information of each component module needs to be determined for further security baseline setting [7]. The common categories of each module of the business system are shown in Fig. 4.1 below.

According to the newly published the *Basic Requirements for the Protection of Network Security Levels (GB/T 22239-2019)*, different levels of protection for business systems have different security protection requirements. The higher the business system level, the greater the security protection requirements. The business system security protection level requirements are also the basis and reference for setting a security baseline [8].

4.2. Research method

Based on the previous research on the business system, understand the basic environment configuration of the business system, and conduct the corresponding security baseline research in combination with the characteristics of the business system. It is mainly divided into three research steps [9]:

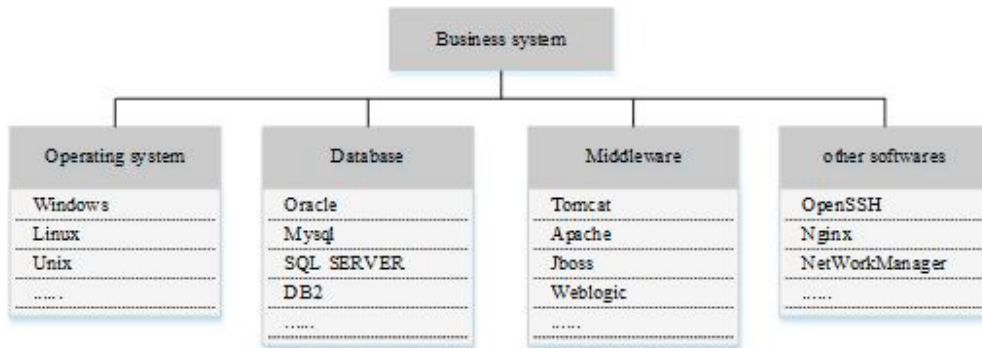


Fig. 4.1. Categories of business systems

Step 1: According to the characteristics of the business system and the level of protection define the corresponding security protection, this step is a relatively macroscopic requirement.

Step 2: According to the operating systems, databases, middlewares and other different system components corresponding to the business system. The safety protection requirements defined in the first step are divided into specific requirements of different modules.

Step 3: According to the specific requirements of different constituent modules of the business system, enumerate the configuration of specific security baseline details such as the basic configuration, status management, and security vulnerabilities of each module.

Based on the detailed research and the analysis of the above three steps, the next work sorts out the corresponding security baseline strategy, and carries out scheme combing and security technology reinforcement. The technology roadmap is shown in Fig. 4.2 above.

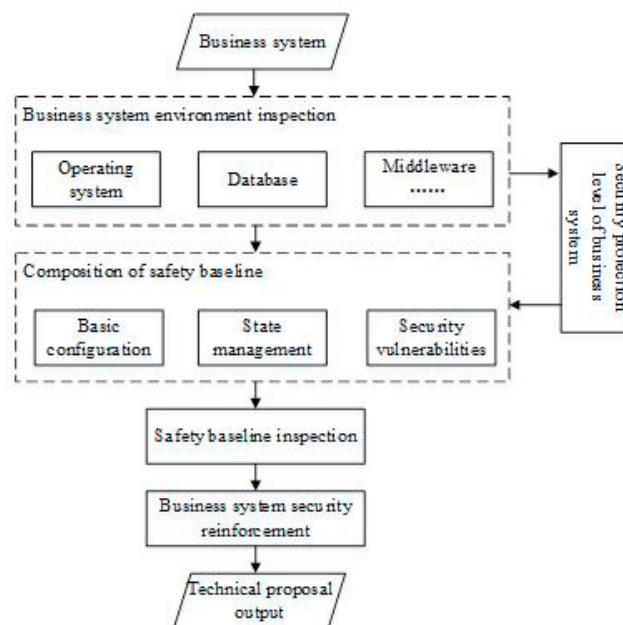


Fig. 4.2. The technology roadmap.

5. Security baseline applications

According to the previous technical research, take a business system as an example, the basic environment of this business system is configured with the operating system type of Centos, the database type of MySQL, the middleware type of JBoss, and the network security protection level is set to Level II. Based on the Level II protection requirements, set the security baseline of each component module in terms of password complexity, identity authentication, log analysis, access control, vulnerability information and other aspects, to write the script, and carry on the corresponding technical examination to the system.

According to the set security baseline plan, the security technology inspection of the business system is performed. The security risk value coefficient of the inspection result is: 6.1. Each inspection item set different weights, and finally evaluate the safety risk score of the whole system^[10]. The score evaluation criteria are shown in Table 5.1 below. According to the following table, the business system is in a dangerous state.

Table 5.1. System safety score evaluation standard.

System risk level	System security score Division
Very dangerous	$7.0 \leq \text{System risk score} \leq 10.0$
Relatively dangerous	$5.0 \leq \text{System risk score} < 7.0$
Relatively safe	$2.0 \leq \text{System risk score} < 5.0$
Very safe	$0.0 \leq \text{System risk score} < 2.0$

For the inspection items that do not meet the safety baseline standard, the main four risk items are shown in Table 5.2 below:

Table 5.2. Main risk items of system baseline inspection

Sequence number	checking point	Inspection scope	result
1	Interface timeout check	Whether the system will log out if it does not operate for more than 10 minutes	Fail
2	Password complexity settings	Password complexity policy, password lifetime, minimum password length, minimum password change interval, warning days before password expiration	Fail
3	User permission setting	Check that users other than the wheel group SU is not allowed to be root	Fail
4	File permission settings	Check important directory or file permission settings	Fail

For the above problems, the first question, edit the `/etc /profile` file and set `TMOUT = 600`. Password complexity setting check more `/etc/login` file, set parameters `PASS_MIN_LEN = 12`, `PASS_MAX_DAYS = 90`, `PASS_WARN_AGE = 7`, and set the password requirement `PAM CRUCKLIB`. So, `TRY_FIRST_PASS` retry = 3, `dcredit = -1` `ocredit = -1`. User permissions mainly check the value of `UID 0`, and file permissions check the value of `UMASK`. According to the solution of the above main problems, the safety baseline check is performed again. The value of the safety risk value is 1.8, and the system is in a very safe state.

6. Summary and prospect

This article briefly introduces the research background, development status, and importance of security baselines in information network security. The security baseline composition divides three aspects effectively: business system basic configuration, state management, and security vulnerabilities. This paper designs a security baseline technology research plan, that combines with the environmental configuration and security protection level of the business system, and sorts out the security baseline policy in line with the business system. Through baseline policies to perform system security inspection, and analyzes the security risk status of business systems. According to the dangerous items of the safety baseline inspection results, strengthen the business system by the security technology. In the case of only

modifying the basic configuration of the system, it does not cost a lot of manpower and resources, reduces the security risk factor of the business system, and ensures the safe and stable operation of the business system.

Information security is a complex system engineering, not only a technical issue, but also need a standard management system to standardize the operation and maintenance management personnel^[11]. Through the construction of safety baseline standard management system, strengthen the basic network safety awareness of enterprise personnel, establish effective safety inspection system and event handling process. It can find security problems in time and deal with them quickly, and provide strong support and guarantee for business system security construction.

References

1. Che Xiangfei. Research on the safety evaluation scheme before the information system goes online [J]. *Software Engineer*, 2015(11):12+17-19.
2. Gui Yonghong. Research and Application of Business System Security Baseline [J]. *Computer Security*, 2011(10):23-27.
3. Shi Jianbing. European Network and Information Security Agency "Guidelines for IoT Security Baseline in Critical Information Infrastructure" [J]. *Information Security and Communication Confidentiality*, 2018, No.289(01):81-96.
4. Lu Ning. Research on Enterprise Information System Architecture and Security Baseline[D].
5. Lan L , Cheng-Rong Z . Design and Implementation of Desktop Security Baseline Management System[J]. *Computer and Modernization*, 2013, 1(2):173-176.
6. Li Dan, Li Yun. Application of Security Baseline Management in Enterprises [J].*Private Science and Technology*, 2013(11):12.
7. Chen Jun. Design and implementation of server security baseline verification based on SCAP[D].
8. Ma Li, Zhu Guobang, Lu Lei. Interpretation of the "Basic Requirements for Network Security Grade Protection" (GB / T 22239-2019) [J]. *Information Network Security*, 2019(02):77-84.
9. Ma Yanhui. Design and Implementation of Database Security Baseline Auto-detection Tool[D].
10. Brooks, W. J , Warren, et al. A Security Evaluation Criteria for Baseline Security Standards[M]// *Security in the Information Society*. Springer US, 2002.
11. Chen Xuehua, Jin Yao, Gu Shumin. Research on Information Security Baseline [J]. *Computer and Network*, 2016, 42(18):52-53.